GRC Practical Project: Launching the Money Transfer Feature at My Wallet

Project Title: GRC Assessment for a Digital Wallet Money Transfer Feature

Project Type: Simulated GRC Project

Role: GRC Analyst

Organization: My Wallet — A fictional digital wallet company

1. Project Overview

In this project, I work as a Governance, Risk, and Compliance (GRC) Analyst at "My Wallet," a fictional company that provides digital wallet services and plans to launch a new feature that allows customers to transfer money to each other.

As the company grows and expands its services, launching this feature requires a balance between achieving business goals and protecting customers' money and data, as well as keeping the service running.

The company faces a challenge because the Risk, Compliance, and Cybersecurity teams work separately. Each team manages its own information and findings without bringing them together into one clear view to support decision-making. Also, the responsibilities for making the launch decision and raising important risks are not clearly defined in the scenario.

Therefore, this project aims to apply the basic concepts of Governance, Risk, and Compliance (GRC) in a connected way, starting with defining the company's objectives, risk appetite, the risks I am willing to accept to achieve my goals, and the risks I am not willing to accept, leading to supporting a well-informed decision about launching the feature.

2. Project Objectives

1. Increase **customer trust** and make the **service easier** to use.
2. **Increase revenue** and help achieve the company's goals.
3. Support **service continuity and reliability**.
4. **Protect** customers' **money and data**.
5. **Consider risks** and **regulatory requirements** before making a **decision.**

3. Methodology

In this project, I will use a step-by-step GRC approach. I will start by defining the **business objectives** and **risk appetite**, then identify **responsibilities**, **assess risks**, review **compliance requirements**, and identify suitable **actions**. Finally, I will bring the results together to support the launch decision and review the results.

4. Step 1: Define Objectives and Risk Appetite

Business Objectives

Increase **customer trust** and convenience, and **raise** the company's **revenue** through the money transfer feature, while **protecting customers' money and data** and **keeping** the **service running.**

Risk Appetite

The initial risk appetite for the project is the willingness to **accept** a **limited delay** in the launch date and **reasonable extra costs** to address risks before launch, in order **to achieve** the **goals**.

Unacceptable Risks

1. Not accepting a **violation** of a **regulatory requirement** that applies to the company or the feature.
2. Not launching the feature while an **unacceptable risk** remains **without** proper **treatment**.

Step 2: Governance

Decision-Making Authority

The proposed approach is to involve **senior managemen**t and the **relevant teams** in the decision to launch the money transfer feature. **Senior management** will **make** the **final decision** to **launch or delay** the feature **based on** the **information and recommendations** provided by the teams.

Roles and Responsibilities

Senior Management: Review the **overall situation** and **make the final decision** to launch or delay the feature.

Risk Team: Identify and assess risks and recommend suitable actions.

Compliance Team: Review regulatory requirements and the available **evidence** of **compliance**.

Technology and Cybersecurity Teams: Review **technical readiness** and **identify technical** and **security issues**.

Application of Governance at My Wallet

The **company** currently **faces** a **problem because responsibilities** for the launch decision are **not clearly defined.** The **proposed governance approach** will help bring the findings of the **different teams together**, provide a **clear view** of the situation, and support an **informed decision** before launching the money transfer feature.

Step 3: Risk Management

This stage aims to identify the risks that may affect My Wallet's objectives, assess their likelihood and impact, and then decide how to deal with them.

Risk Identification and Assessment

In this stage, we will start with the risks identified in the project scenario: fraud, transfer errors, and service outages.

Risk 1: Fraud

Potential Impact:

Fraud may seriously **damage** the company's **reputation**, **harm customers**, and cause them to **lose trust** in My Wallet. The company may also face **financial losses** due to compensating affected customers. **Even** after **compensation**, the **company's image** may remain **weak** in the eyes of **customers and the market.**

Information Needed to Assess Likelihood:

The company must identify the **security controls** in place to **reduce fraud**, **check** how **effective** they are, and **review** the **evidence** that proves they are implemented. The results of this review should then be **used** to **estimate** the **likelihood** of fraud.

Assessment Status: The **likelihood** level **has not yet been** determined **because** there is **no confirmed information** about the controls in place or their effectiveness.

Risk 2: Transfer Errors

Potential Impact:

Transfer errors may cause **financial losses** for customers, lead to a **loss of trust** in My Wallet, and **damage** the company's **reliability and reputation**. The company may also face **costs to investigate and correct errors** .

Information Needed to Assess Likelihood:

The company must identify the **controls** in place to **prevent** or **deteced** transfer errors , check their **effectiveness**, and review the **evidence** that proves they are implemented. Transfer test results and previous error logs, if available, can also be reviewed to estimate the likelihood of these errors.

Assessment Status: The likelihood level has not yet been determined because there is no confirmed information about the controls in place or their effectiveness.

Risk 3: Service Outage

Potential Impact:

A service outage may reduce the availability of My Wallet's services, preventing customers from transferring money or accessing their wallet services. This may lead to customer dissatisfaction, loss of trust in the company, and damage to its reputation. The company may also lose revenue during the outage and incur costs to restore the service to normal operation.

Information Needed to Assess Likelihood:

The company must determine whether it has procedures in place to reduce the likelihood of service outages. It should also review previous outage records and service recovery test results, if available, to help estimate the likelihood of an outage.

Assessment Status:

The likelihood level has not yet been determined because there is no confirmed information about the procedures in place or their effectiveness.

Risk Treatment

Risk 1: Fraud

Objective: To **reduce** the **likelihood** of **fraud**, **protect customer** funds, and **maintain customers' trust** in My Wallet.

Proposed Risk Treatment Actions:

User and Employee Awareness: Educate users about fraud methods, such as phishing, and how to protect their login credentials and verification codes. **Employees** should also receive **training** to identify fraud attempts and handle suspicious cases.

Multi-Factor Authentication for Transfers: Apply **multi-factor authentication** to strengthen user identity verification and reduce the likelihood of unauthorized transfers, using an authentication method appropriate to the level of risk.

Automated Fraud Detection Rules: Develop automated **rules** to **monitor transfers** and **detect unusual pattern**s, such as repeated transfers within a short period or behavior that differs from a customer's usual activity.

A Risk-Based Approach to Suspicious Transfers: Define **appropriate actions** based on the **level of suspicion**. These may include requesting **additional verification** from the **customer**, temporarily **holding** a transaction **for review**, or **blocking** a transaction when the level of **suspicion is high** and predefined rules justify the action. The **process** should account for **false alerts** and provide a way to **resolve cases** confirmed to be **legitimate**.

How to Verify the Effectiveness of the Actions:

The **company** should **verify** that these **actions** have been **implemented**, test their **effectiveness**, and **review** the **results** and supporting evidence **before** reassessing the **residual risk** and **determining** whether it is acceptable.

Risk 2: Transfer Errors

Objective: To reduce the **likelihood** of money **transfer errors,** ensure that the correct amount reaches the **correct recipient**, and maintain customers' trust in My Wallet.

Proposed Risk Treatment Actions:

Displaying the Recipient's Name and Transfer Amount Before Confirmation: Display the **recipient's name** and the **amount** to be transferred clearly **before executing** the transaction, allowing the **customer** to **review** the **details** and verify their accuracy before confirming.

Ensuring That the System Processes the Entered Data Correctly: Verify that the **system processes** the **transfer** details and **executes** the transaction **according** to the **recipient** and **amount entered** and **confirmed** by the **customer**, ensuring that **no unintended** changes occur to the transfer details.

Testing Transfer Scenarios: Test different **transfer scenarios,** including the **Happy Path**, where the transaction is **completed successfully**, and the **Sad Path**, which covers **error cases** or unexpected situations. This helps **ensure** that transfers are **executed correctly** and **errors** are **handled** without causing unintended outcomes.

How to Verify the Effectiveness of the Actions:

These **actions** should be **tested**, and the test results and supporting **evidence** of their **implementation** should be reviewed to verify their **effectiveness before** reassessing the **residual risk** and **determining** whether it is acceptable.

Risk 3: Service Outage

Objective: To reduce the likelihood of service outages, minimize their impact when they occur, and ensure that services are restored as quickly as possible.

Proposed Risk Treatment Actions:

Continuous 24/7 Service Monitoring: Continuously monitor system and service performance, with **automated alerts** configured to detect **failures or signs** of potential problems, ensuring timely detection and response.

Backups, Alternative Servers, and Redundancy: Maintain **data backups** and update them according to service **requirements**, while testing their **recoverability**. Prepare **alternative servers** and implement redundancy to **reduce the likelihood** of a complete **service outage** if one system component fails.

Recovery and Restoration Plan: Develop a **plan** that defines the procedures and responsibilities required to **restore services** and data after an outage, aiming to **return operations** to normal as quickly as possible and minimize the impact on customers and the company.

Outage and Recovery Testing: Conduct regular **tests simulating service outages** to **verify** that **alternative systems** can operate, backups and the recovery plan are effective, and weaknesses requiring remediation are identified.

How to Verify the Effectiveness of the Actions:

Review monitoring logs and alerts, verify successful backup restoration, examine outage and recovery test results, and review evidence demonstrating that the actions have been implemented and are effective. The results should be used to reassess the residual risk and determine whether it is acceptable.

Step 4: Compliance

Objective

The objective of this stage is to identify the legal and regulatory requirements applicable to My Wallet and its new money transfer feature, assess the current compliance status, and identify gaps and the evidence required to demonstrate compliance.

ISO 37301 will be used as a reference for structuring the compliance management process. It does not replace applicable laws, legislation, or instructions issued by the relevant regulatory authorities.

4.1 Identifying Legal and Regulatory Requirements

By referring to official sources published by the Central Bank of Jordan and other relevant authorities, we identified several legal and regulatory areas that must be reviewed to determine their applicability to My Wallet and its new money transfer feature.

1. Licensing and Authorization

Review the company's existing license and the services it is authorized to provide. Determine whether the new customer-to-customer money transfer feature falls within the scope of the existing license or requires additional approval or another regulatory procedure.

2. Anti-Money Laundering and Counter-Terrorist Financing (AML/CFT)

Review the applicable requirements relating to customer identity verification, customer due diligence, financial transaction monitoring, and the handling and reporting of suspicious activities in accordance with relevant legislation.

3. Financial Consumer Protection

Review applicable requirements relating to transparency, fees and commissions, customer agreements, protection of customer information, complaint handling, and the protection of electronic payment accounts against fraud and unauthorized access.

4. Technical Requirements and Cybersecurity

Identify the technical, operational, and security requirements applicable to payment service providers. Verify whether the required controls have been implemented and whether evidence is available to demonstrate their implementation.

5. Governance and Compliance Responsibilities

Review applicable governance requirements and verify that responsibilities for regulatory compliance, internal oversight, escalation, and reporting are clearly defined.

6. Personal Data Protection

Identify the personal data protection requirements applicable to the customer data processed by My Wallet. Review the relevant policies, procedures, and evidence relating to the protection of that data.

4.2 Legal and Regulatory Sources for Review

The initial assessment will rely on official sources published by the Central Bank of Jordan and other relevant authorities. The validity of each requirement, its scope of applicability, and any relevant amendments must be verified.

The primary sources to be reviewed include:

- Electronic Payment and Electronic Money Transfer System No. 111 of 2017, along with related payment system legislation and instructions.
- Corporate Governance Instructions for Electronic Payment and Money Transfer Companies No. 11 of 2025, subject to verification of their current status, applicability, and any relevant transitional provisions.
- Anti-Money Laundering and Counter-Terrorist Financing Instructions for Electronic Payment and Electronic Money Transfer Service Companies No. 12 of 2018, subject to verification of any amendments or more recent requirements.
- Financial Consumer Protection Instructions for Electronic Payment and Electronic Money Transfer Companies No. 3 of 2021.
- Technical Requirements Instructions for Electronic Payment and Electronic Money Transfer Service Companies No. 8 of 2018, together with other applicable technical and security requirements.
- Personal Data Protection Law No. 24 of 2023 and its related regulations and instructions.

Official sources for review:

- Central Bank of Jordan: Payment System Legislation
- Central Bank of Jordan: Instructions
- Central Bank of Jordan: Anti-Money Laundering and Counter-Terrorist Financing Instructions

This is a preliminary list for review. It does not mean that all the listed requirements automatically apply to the company. The applicability of each requirement must be verified before it is formally adopted as a legal or regulatory obligation of My Wallet.

4.3 Compliance Obligations Register

A Compliance Obligations Register will be developed to document the requirements identified during the review and link each requirement to the responsible party and the evidence needed to demonstrate compliance.

For each requirement, the register will include:

- Name of the law, regulation, or instruction and its reference number.
- Applicability to the company and the money transfer feature.
- The specific obligation the company must fulfill.
- The department or individual responsible for implementation.
- Evidence required to demonstrate compliance.
- Current compliance status.
- Any identified gap and the required corrective action.

The initial status of each requirement will be recorded as **Pending Verification** until the available information and evidence have been sufficiently reviewed.

4.4 Evidence Required to Demonstrate Compliance

The company will identify appropriate evidence for each requirement based on its nature. Such evidence may include licenses and approvals, approved policies and procedures, customer verification records, technical testing reports, complaint records, and review reports.

The evidence must be reviewed to determine whether it is relevant, sufficient, and up to date. The mere existence of a document is not enough; the review must establish what the document actually demonstrates.

4.5 Compliance Status and Gap Assessment

Each requirement will be assigned one of the following statuses:

Compliant: Sufficient evidence has been reviewed to support the conclusion that the company has fulfilled the applicable requirement.

Non-Compliant: The available evidence indicates that the company has not fulfilled an applicable requirement.

Pending Verification: The applicability of the requirement or the sufficiency of the available evidence has not yet been confirmed.

When a gap is identified, the company will document the required corrective action, assign responsibility for implementation, establish a target completion date, and retain evidence demonstrating that the gap has been addressed.

4.6 Use of ISO 37301

ISO 37301 will be used as a reference for structuring the compliance management process through the identification of obligations, allocation of responsibilities, compliance monitoring, evidence documentation, and remediation of identified gaps.

This project does not assume that My Wallet has implemented ISO 37301 or obtained certification against it. Instead, the standard will guide the proposed methodology for managing compliance.

Expected Outcome

This stage will produce a preliminary Compliance Obligations Register identifying the requirements that need to be reviewed, the evidence required to demonstrate compliance, and any gaps requiring verification or remediation.

The results will support the assessment of the money transfer feature's readiness before a launch decision is made.

Step 5: Control Assessment

Objective

The objective of this stage is to review the existing controls at My Wallet, **identify any gaps**, and determine the actions **needed** to improve the **security** and reliability of the new money transfer feature.

5.1 Reviewing Existing Controls

The GRC team will review the controls related to the three main risks identified in Step 3:

- **Fraud: Review** the measures used to detect **suspicious** transactions and protect customer accounts.
- **Transfer Errors: Review** the measures used to ensure that **transfers** are executed to the correct recipient and for the correct amount.
- **Service Outages: Review** monitoring, backup, and recovery measures designed to maintain service availability.

The review will also consider the controls required to meet the applicable legal and regulatory obligations identified in Step 4.

5.2 Identifying Control Gaps

The GRC team will **compare** the required **controls** with the controls currently implemented by My Wallet to identify missing or ineffective measures.

The assessment will be based on available evidence. If the implementation or effectiveness of a control cannot be confirmed, its status will be recorded as **Pending Verification**.

5.3 Defining Corrective Actions

For each identified **gap**, the GRC team will document the **required corrective** action, assign **responsibility** to the relevant department, and establish a target completion date.

For example, if appropriate verification for suspicious transfers is missing, the proposed action may be to implement additional verification measures.

Expected Outcome

This stage will produce a concise list of control gaps and corrective actions, helping My Wallet address weaknesses before reassessing the remaining risks and supporting the final launch decision.

Step 6: Residual Risk Assessment

Objective

The objective of this stage is to reassess the risks associated with My Wallet's new money transfer feature after considering the **controls implemented** and the **corrective actions** completed. The purpose is to determine whether the remaining risks are acceptable under the company's defined risk appetite.

6.1 Reassessing Identified Risks

The three risks identified in Step 3 will be **reassessed**:

- **Fraud:** Determine whether the implemented controls adequately reduce the likelihood or impact of fraudulent transactions.
- **Transfer Errors:** Determine whether the controls effectively reduce the likelihood and impact of incorrect transfers.
- **Service Outages:** Determine whether monitoring, backup, and recovery measures adequately reduce the risk of service disruption.

The reassessment will consider the actual implementation status and effectiveness of the controls, supported by available evidence.

6.2 Determining Residual Risk

For each risk, the GRC team will reassess its likelihood and impact after considering the verified controls and completed corrective actions.

The resulting residual risk level will be compared with the company's risk appetite to determine whether further treatment is required.

If the available evidence is insufficient to confirm control effectiveness, the residual risk will be recorded as **Pending Verification** rather than assumed to have decreased.

6.3 Further Risk Treatment

If a residual risk exceeds the company's acceptable risk level, the GRC team will recommend additional treatment actions, such as implementing further controls, improving existing measures, or delaying the feature until critical weaknesses are addressed.

Any remaining risk that requires management acceptance will be presented to the appropriate decision-maker, together with its potential impact and the available treatment options.

Expected Outcome

This stage will produce an updated risk assessment showing the initial risks, the verified controls, the residual risk levels where they can be established, and any further actions required.

Step 7: Launch Readiness and Decision

Objective

The objective of this stage is to consolidate the results of the risk, compliance, and control assessments to determine the readiness of the new money transfer feature for launch and provide a clear recommendation to support management's final decision.

7.1 Reviewing Assessment Results

The GRC team will review the following results:

- **Risk:** Determine whether the residual risks fall within the company's defined risk appetite.
- **Compliance:** Verify whether the applicable legal and regulatory requirements have been met.
- **Controls:** Confirm that critical weaknesses have been addressed and that the required controls have been verified as effective.
- **Corrective Actions:** Review the status of required actions and confirm that issues that could prevent launch have been addressed.

7.2 Preparing the Launch Recommendation

Based on the assessment results and available evidence, the GRC team will provide management with one of the following recommendations:

- **Launch:** If essential requirements have been met, unacceptable risks have been addressed, and the required controls have been verified.
- **Delay Launch:** If critical gaps or corrective actions remain outstanding, or if compliance with relevant requirements has not yet been verified.
- **Do Not Launch:** If unacceptable risks or legal or regulatory barriers remain that cannot be accepted or adequately addressed.

7.3 Making and Documenting the Decision

Senior management will make the final decision to launch, delay, or cancel the feature based on the assessment results, the GRC team's recommendation, and information provided by the relevant departments.

The decision will be documented along with its rationale, any accepted residual risks, actions that must be completed before launch, and the responsibilities assigned for those actions.

Expected Outcome

This stage will produce a documented recommendation on the readiness of the money transfer feature, supported by the risk, compliance, and control assessment results. It will also document management's final decision and any actions required before launch.

Step 8: Monitoring and Continuous Improvement

Objective

The objective of this stage is to monitor the money transfer feature after launch, identify emerging risks or control weaknesses, and ensure that the company's risk management and compliance processes remain effective.

8.1 Ongoing Monitoring

The relevant teams will monitor the feature for issues such as:

- **Fraud:** Suspicious **transactions** and unusual customer activity.
- **Transfer Errors:** Incorrect or **failed transfers** and customer complaints.
- **Service Availability:** Outages, **system failures**, and recovery performance.
- **Compliance: Changes** in **applicable legal** and regulatory requirements and continued compliance with existing obligations.

8.2 Reviewing Controls and Incidents

The company will **periodically review control** effectiveness, investigate significant incidents, and identify the reasons behind failures or weaknesses.

Where necessary, the relevant teams will update controls, revise procedures, and implement corrective actions to prevent similar issues from recurring.

8.3 Continuous Improvement

The GRC team will coordinate with Risk, Compliance, and Technology to review monitoring results, track corrective actions, and report significant issues to management.

Changes to the feature, business operations, or regulatory requirements will trigger a review of the relevant risks and controls.

Expected Outcome

This stage will establish an ongoing process for monitoring risks, maintaining compliance, reviewing control effectiveness, and addressing new issues. The results will support continuous improvement and help My Wallet maintain the security, reliability, and trustworthiness of its money transfer feature.